

Reported Account Compromise & Phishing-Email Claim — Forensic Verification

Classification: Internal — Confidential

Field	Value
Case Reference	INC-2021-1116-01
Evidence Sources	Email + embedded attachment & supporting attachment file
Incident Date/Time	2021-11-16, 11:31:51 UTC+3
Reporting Party	I. Alzaid (ixxxxxx@stc.com.sa)
Subject Account	F. Almobarak (fxxxxxxx@stc.com.sa)
Report Status	Final — High Confidence
Prepared By	Aljoharah Alqahtani — Cybersecurity Analyst

1. Reported Claim

As briefed

It was reported that F. Almobarak's account was compromised and used to send phishing emails to multiple employees, that recipients interacted with them, and that their devices were subsequently compromised. This report verifies that claim against the available evidence.

2. Executive Summary & Verdict

Static and dynamic analysis of both provided samples — independently corroborated across two separate sandbox runs — show the attachment's only behavior is opening a browser link (YouTube in the draft build, an official CITC anti-phishing awareness PDF in the version actually delivered). No code execution, malicious process, or network threat was observed in either sample. Email transport evidence places the message inside F. Almobarak's own mailbox, delivered internally via MAPI, with no indicators of spoofing.

Confidence is split across two distinct questions:

- Is the file itself malicious? — High confidence: No. Confirmed by two independent methods (static code + live sandbox execution) across both samples.
- Was the account genuinely authorized to send this, vs. compromised? — Medium confidence: content and delivery-path evidence argue against compromise, but this has not been independently confirmed via Identity/Entra sign-in logs or a campaign-approval record (Section 5).

Supporting this reading: an attacker with real high-privilege access over a senior IR analyst's account would have far more to gain from credential harvesting or lateral movement than from redirecting recipients to a government awareness page — the payload's lack of any exploitable value is itself circumstantial evidence against a genuine compromise scenario.

3. Key Findings

Area	Result
Macro behavior (both samples)	Static code and live sandbox execution match exactly: single browser navigation only — no download, drop, or scripting
Email delivery path	Sender resolves to F. Almobarak's own mailbox; internal MAPI-only delivery (no SMTP/Received headers); no spoofing indicators
File integrity	Two samples confirmed as distinct builds via SHA-256 (draft: 32-bit/youtube.com; delivered: 64-bit/CITC PDF)
Dynamic sandbox (both samples)	0 malicious / 0 suspicious processes, 0 network threats; traffic limited to CITC or YouTube plus standard whitelisted MS/Google telemetry
Initial "suspicious" sandbox flag (WinRAR/PowerShell)	Did not reproduce in the second sandbox run — assessed as a tooling artifact, not attachment-related

4. Claim Verification

Reported Claim Element	Assessment	Basis
Account compromised & used to send phishing email	Not supported	Mailbox/authorship match F. Almobarak; MAPI-only delivery. Not fully closed without Identity logs (Sec. 5)
Attachment is malicious	Not supported	Static + dynamic analysis, both samples, both converge on benign navigation only
Multiple employees interacted with it	Cannot be assessed	Only one recipient (I. Alzaid) present in evidence provided
Devices subsequently compromised	Not supported by evidence	Attachment has no capability beyond opening a URL; no endpoint data available

5. Limitations & Next Steps

- Only one recipient was available for testing — verify against any other employees named in the original report.
- Independently confirm the citc.gov.sa IP/DNS resolution seen in the sandbox is legitimate CITC infrastructure, not a spoofed or hijacked entry.
- Obtain Identity/Entra ID sign-in logs for F. Almobarak 's account and the security-awareness campaign approval record to close the authorization question with full confidence.
- Chain of custody for both samples is not documented in the materials provided.
- An alternative explanation — a more sophisticated actor using a benign first-stage link before a separate later attack — was considered; no evidence of a second stage was found in either static or dynamic analysis, but this cannot be fully excluded beyond the scope tested.

6. References

All static and dynamic analysis evidence can be found [here](#).

Prepared by Aljoharah Alqahtani — Cybersecurity Analyst.